<CLIENTNAME> Information Risk Management Policy

<CLIENTNAME>-ORG-IMS-POL-026

Abstract

The Information Risk Management Policy sets the premise for ensuring all Information risks affecting confidentiality, integrity and availability, secrecy and privacy of <CLIENTNAME>'s Information and Communication Technologies (ICTs) are identified, evaluated, treated and monitored efficiently and effectively.

STATEMENT OF CONFIDENTIALITY

All information in this document is <CLIENTNAME> PRIVILEGED and for INTERNAL USE ONLY.

The information in this document may contain <CLIENTNAME> proprietary trade secrets and confidential information, the disclosure of which could substantially benefit competitors. As a result, this document should not be disclosed, used or duplicated – in whole or in part without the explicit authorization of <CLIENTNAME> management.

The information is intended solely for the use of authorized recipients. If you are not the intended recipient, you are prohibited from reading, using, disseminating, distributing and copying this document.

In accessing the document, the reader warrants that the information contained herein shall only be treated for internal use. No content of any nature shall be shared with any other external party or unauthorized recipient.

Document Information	
Document ID	<CLIENTNAME>-ORG-IMS-POL-026
Document Title	<CLIENTNAME> Information Risk Management Policy
Prepared by	
Status	
Owner	
Effective From	
Effective Till	
Document Type	
Document Classification	
Distribution List	

Document Release Dates			
Version	**Date**	**Editor**	**Brief/Comments**
0.1			
0.2			
1.0			
1.1			

Document Review			
Date	**Name**	**Title/Designation**	**Notes**

Approvals		
Name	**Title/Designation**	**Signature**

Table of Contents

1. INTRODUCTION 5
2. PURPOSE 5
3. SCOPE 5
4. POLICY STATEMENT 6
5. POLICY DETAILS 6
5.1. Information Risk Management Framework 6
5.2. Information Risk Assessment 6
5.3. Information Risk Categorization 7
5.4. Information Risk Treatment 7
5.5. Selection of Controls 8
5.6. Information Risk Monitoring 8
6. ROLES AND RESPONSIBILITIES 9
7. POLICY ENFORCEMENT AND EXCEPTIONS 9
8. MONITORING AND REVIEW 10
9. POLICY - UAE IA Control Mapping 11

1. INTRODUCTION

This Information Risk Management Policy ("Policy") is a key component of <CLIENTNAME>'s overall Integrated Management System (IMS) and overarches the detailed risk management framework and procedure. Adherence to this Policy will help protect <CLIENTNAME> against known and unknown information security risks, whether internal or external, deliberate or accidental.

<CLIENTNAME> recognizes that effective identification and management of risk is mandatory to the functioning of a robust Integrated Management System (IMS) comprising of Information Security Management System (ISMS), IT Service Management System (ITSMS), Business Continuity Management System (BCMS) and Privacy Information Management System (PIMS).

This Policy will be reviewed at least annually or following any changes to contributing internal or external factors.

2. PURPOSE

The purpose of this Policy is to ensure that information risks in the organization are identified, assessed, evaluated, monitored, reported and treated according to the business, security, privacy and continuity requirements and objectives of the organization.

Further, the Policy establishes a commitment to comply with applicable sections of the federal laws and regulations, including but not limited to UAE Information Assurance Regulation (UAE IAR) and ISO 27001.

The following are the key objectives of this Policy:

2.1 **Establish an Information Risk Management Framework:** Establishment of an organization-wide Information Security Risk Management Framework.

2.2 **Address Information Security (IS) risks:** Identification, analysis and evaluation of organizations IS risks to select appropriate IS risk treatment options.

3. SCOPE

This Policy encompasses all system components that are owned, leased, rented, operated, maintained, and otherwise controlled by <CLIENTNAME> or a third-party on behalf of <CLIENTNAME>, and also applies to any system or system components, both internally and externally, that interact with these systems.

This Policy applies to all employees and contractors who access or manage information and information assets or use the organization's information and communications technology (ICT) systems.

Any exceptions on the applicability of this Policy should be formally requested through the Policy Exception Management procedure.

4. POLICY STATEMENT

<CLIENTNAME> shall implement an information risk management program that shall require conducting risk assessments, identifying information risks, treating the risks and continuously monitoring risks by evaluating the effectiveness of information security controls to ensure efficient risk handling.

5. POLICY DETAILS

5.1. Information Risk Management Framework

5.1.1 <CLIENTNAME> shall define an Information Risk Management (IRM) framework that provides a process to integrate security, privacy, and business continuity risk management activities into business processes.

5.1.2 The IRM framework shall consider business objectives and constraints placed by applicable laws, directives, executive orders, policies, standards, or regulations.

5.1.3 <CLIENTNAME>'s IRM framework shall include the following activities at a minimum:

a. Prepare: Establish context by understanding mission, business objectives, and information systems to manage <CLIENTNAME>, its security, privacy, and business continuity risks.

b. Identify: Provide a structured way to determine the criticality of the information assets at <CLIENTNAME>, and identify its associated risks.

c. Assess: Analyze, evaluate and categorize risks based on its likelihood of materializing and its impacts to <CLIENTNAME>'s business and information systems.

d. Select: Select, tailor and document the controls necessary to protect <CLIENTNAME> and its information systems commensurate with risks.

e. Implement: Establish new or utilize existing processes, procedures, tools and technologies to meet the intent of selected controls.

f. Review: Determine whether the selected controls are implemented correctly, operate as intended, and produce the desired outcomes to meet <CLIENTNAME>'s information security and data privacy requirements.

g. Monitor: Maintain ongoing situational awareness about the security and privacy posture of <CLIENTNAME> and its information systems to support risk management decisions.

5.1.4 The IRM framework shall establish and implement a plan for communicating risk information and consulting key stakeholders, including decision-makers within the organization during all stages of the risk management process.

5.2. Information Risk Assessment

5.2.1 <CLIENTNAME> shall establish a risk assessment process to be used as the basis for the identification, definition and prioritization of risks.

5.2.2 The risk assessment process shall include at a minimum:

a. Identification of the vulnerabilities that exist in the information assets.

b. Identification of threats that may exploit a vulnerability.

c. Qualitative analysis and evaluation of the impact to the confidentiality, integrity, availability, secrecy and privacy of information assets if a threat exploits vulnerabilities.

d. Identification and definition of measures and/or controls used to protect the confidentiality, integrity, availability, secrecy and privacy of information assets.

5.2.3 The risk assessment shall be performed/updated when environmental, operational or technical changes arise that impact <CLIENTNAME>'s business processes and information assets. Such changes include but are not limited to:

a. New threats or risks with respect to the business processes and information assets.

b. An information security incident.

c. Outcomes of any internal or external assessments.

d. Changes to information security requirements or responsibilities. (e.g., new federal or state law or regulation, new or modified security controls implemented, etc.).

e. Changes to the <CLIENTNAME>'s organizational or technical infrastructure that impact information assets (e.g., addition of a new network, new hardware/software standard implemented, new method of creating, receiving, maintaining or transmitting data, etc.).

5.3. Information Risk Categorization

5.3.1 <CLIENTNAME> shall categorize risks based on business objectives, data sensitivity, threat exposure and vulnerabilities pursuant to information assets.

5.3.2 The categorization process shall take into account the probability and impact of risks materializing and affecting business objectives.

5.3.3 Risks shall be expressed qualitatively as per the risk categorizations defined under the Information Risk Management Framework.

5.3.4 Adequate resources to address risks shall be allocated according to the risk categorization.

5.4. Information Risk Treatment

5.4.1 <CLIENTNAME> shall select and implement risk treatment measures to reasonably protect the confidentiality, integrity, availability, secrecy and privacy of information assets. One or more of the following methods shall be used to manage risk:

a. Risk Reduction: Reducing risk by applying security controls.

b. Risk Avoidance: Avoiding the activity or condition causing the risk.

c. Risk Transfer: Transferring the risk to another party.

d. Risk Retention: Accepting the risk based on the organization's risk acceptance criteria established in the Information Security Risk Management Framework.

5.4.2 <CLIENTNAME> shall document a risk treatment plan to outline the approach to be used to treat the risks. Such risk treatment plans shall include at a minimum:

a. Description of information risks.

b. Appropriate management actions.

c. Responsibilities and priorities for managing information security risks (risk ownership).

d. Target dates for implementation of the identified controls.

5.4.3 Risk treatment plans shall be monitored and reviewed periodically as deemed necessary to ensure that risk is managed on a continuous basis.

5.5. Selection of Controls

5.5.1 <CLIENTNAME> shall select and implement appropriate controls to mitigate identified risks based on relevance, nature, feasibility and cost effectiveness of the controls.

5.5.2 Under the <CLIENTNAME> Integrated Management System (IMS), controls shall be selected from the list of following standards/frameworks/regulations, inclusive of but not limited to:

a. ISO 27001.

b. ISO 27701.

c. ISO 22301.

d. UAE Information Assurance (IA) Regulation.

5.6. Information Risk Monitoring

5.6.1 <CLIENTNAME> shall continuously review and monitor outcomes of risk assessment and treatment. The monitoring processes shall evaluate:

a. The effectiveness of security controls.

b. Changes to information assets and environments of operations.

c. Compliance with federal and state laws and regulations and applicable standards.

6. ROLES AND RESPONSIBILITIES

Role	Responsibility
Executives & Senior Management	6.1 Make available and support the required resources to drive IS Risk Management. 6.2 Where relevant, provide direction to and participate in reviews and oversight of IS risk management. 6.3 Review and approve this Policy and associated procedures prepared by or on behalf of Information Security Team.
IS (Information Security) Team	6.4 Develop and implement an information security risk management framework. 6.5 Ensure information security risks are identified and classified. 6.6 Conduct and document information security risk assessments and risk analysis. 6.7 Evaluate the IS risks and determine appropriate risk treatment options. 6.8 Ensure proper creation and documentation of Risk Treatment Plans. 6.9 Assess risk treatment option chosen by deciding whether residual risk levels are tolerable. 6.10 Ensure proper information security controls are identified. 6.11 Ensure proper implementation the information security risk assessment review and update processes. 6.12 Ensure continuous and proactive monitoring of security incidents. 6.13 Ensure proper creation and documentation of Risk Communication Plan.
IT (Information Technology) Team	6.14 Implement information security controls as needed to mitigate vulnerabilities.
Employees and Third Parties (Contractors, Vendors, etc.)	6.15 Employees and third parties (including contractors, vendors, etc.) who access organizational premises, information and information assets or use information and communications technology (ICT) systems of the organization are responsible for adhering to this Policy and all its applicable procedures. 6.16 Line Managers to ensure that all personnel under their direct supervision comply with this Policy.
Legal	6.17 Identify all relevant and applicable laws and regulations to <CLIENTNAME> and communicate to the respective parties. 6.18 Define standard legal clauses and terms for the contract/agreement to be signed with external parties, employment contracts, confidentiality and Non-Disclosure Agreements (NDAs). 6.19 Liaise with IS Team to define and review Information Security clauses in third-party contracts/agreements, employment contracts, confidentiality and Non-Disclosure Agreements (NDAs). 6.20 Review third-party vendor, clients and partner contracts and involve IS Team for review of clauses concerning Information Security responsibilities

7. POLICY ENFORCEMENT AND EXCEPTIONS

All employees and contractors are responsible for understanding and adhering to this Policy. Any violation of this Policy shall be reported to Policy Owner. Violation of this Policy shall be subjected to disciplinary action by the <CLIENTNAME>'s Human Capital

Department, taking into consideration the recommendation of IS Team and in accordance with other applicable policies, laws and regulations.

Disciplinary action may range from a verbal warning to discontinuation of access to facility or services, or termination of employment/contract/agreement, and possible legal action. The actual action taken shall depend on factors such as the seriousness of the breach and the user's disciplinary record.

Any exceptions on the applicability of this Policy should be formally requested through the Policy Exception Management procedure.

8. MONITORING AND REVIEW

This Policy is developed by <CLIENTNAME> Information Security (IS) Team, owned and reviewed by the CISO. It is approved by the CEO.

<CLIENTNAME> IS Team shall initiate a review of this Policy annually or whenever a significant change occurs in the organization's operating environment.

Feedback, suggestions or questions regarding the Policy shall be directed to the <CLIENTNAME> IS Team at infosec@<clientname>.net.

9. POLICY - UAE IA Control Mapping

Policy Sections	UAE IA - Control	ISO 27001:2022
Section 1 Introduction	M2.1.1 – Risk Management Policy	Clause 6.1.2 and Clause 6.1.3
Section 2 Overview and Purpose	M2.1.1 – Risk Management Policy	Clause 6.1.2 and Clause 6.1.3
Section 3 - Scope, Exclusions	M2.1.1 – Risk Management Policy	Clause 6.1.2 and Clause 6.1.3
Section 4 – Policy Statement	M2.1.1 – Risk Management Policy	Clause 6.1.2 and Clause 6.1.3
Section 5 – Policy Details	NA	NA
5.1 – Information Risk Management Framework	M2.1.1 – Risk Management Policy	Clause 6.1.2 and Clause 6.1.3
5.2 – Information Risk Assessment	M2.2.1 – Information Security Risk Identification M2.2.2 – Information Security Risk Analysis	Clause 6.1.1, Clause 6.1.2(c) and Clause 6.1.2 (d)
5.3 - Information Risk Categorization	M2.2.2 – Information Security Risk Analysis M2.2.3 – Information Security Risk Evaluation	Clause 6.1.2 (d) and Clause (e)
5.4 - Information Risk Treatment	M2.3.1 – Information Security Risk Treatment Options M2.3.3 – Risk Treatment Plan	Clause 6.1.3 (a) and Clause 6.1.3 (e, f)
5.4.1 - Selection of Controls	M2.3.2 – Identification of Controls M2.3.4 – Statement of Applicability	Clause 6.1.3 (a) Clause 6.1.3 (d)
5.5 - Information Risk Monitoring	M2.4.1 – Information Security Risk Assessment Review and Update	Clause 8.2